SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Accredited by NAAC A Grade

Assignment I

CO1: Apply the foundational concepts of ethical hacking — types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cyber security.

Evaluation note: This is a design/portfolio assignment. Each task is marked on the evidence listed in the question paper. Award marks for correct governance decisions, working artefacts (tables, workflows, documents, lab design) and demonstrated integration between components — not for listing tools. Accept equivalent correct designs.

Name of the Student : SANA FATHIMA M

Register No : 192371082

Department : CSE

Sub Code / Name : ITA1405

Date of Submission : 06/11/2026

Total Marks:

SANA FATHIMA M

Student Signature **Faculty Signature**

ITA14 Ethical Hacking ASSIGNMENT 1

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

---

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, thirdparty assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint **4 Marks**

- Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.
- Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.
- Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.
- Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification **4 Marks**

- Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.
- Map each type to its motivation, typical capability and likely targets within the university.
- Establish clear criteria and naming so that an actor can be classified consistently.
- Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module **4 Marks**

- Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.
- Design rules or checks that help detect or prevent unethical actions during an engagement.
- Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.
- Explain how the module preserves trust and keeps the engagement lawful and professional.

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping **4 Marks**

- Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
- Build a table of offences, obligations and penalties related to unauthorized access and data protection.
- Connect each legal requirement to a specific control in the engagement framework.
- Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document **4 Marks**

- Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.
- Create rules for recording and verifying the written authorization behind each engagement.
- Establish clear naming and boundaries so that an out-of-scope request can be detected.
- Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived preengagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer **5 Marks**

- Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.
- Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.
- Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.
- Create rules for choosing between coordinated and full disclosure for a given finding.
- Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab **5 Marks**

- Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.
- Specify the components, roles and connectivity of the lab and the steps used to record its configuration.
- Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.
- Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.
- Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library **4 Marks**

- Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.
- Use sensible default fields where appropriate and explicitly design the content of each document.
- At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.
- Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework **4 Marks**

- Integrate the components created in Tasks 2-8 into one coherent engagement framework.
- Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.
- Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.
- Record the problems encountered during the walkthrough and show how the framework was refined to address them.

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation **4 Marks**

- Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved.
- Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.
- Create a comparison table and at least one suitable chart or structured visualization.
- Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks

- Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
- Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
- Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
- Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
- Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5

TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50

Executive Summary

A university is launching an Authorized Security-Assessment Programme covering roughly 20 systems (student portal, learning-management system, email service and campus network) and 50 staff, with expected growth to the whole university and to external, third-party assessors. This report presents an integrated **Ethical-Hacking Engagement Framework** produced by the Ethical-Hacking Governance Team. It answers every task in Assignment 1 in question-and-answer form and supplies the expected evidence for each: requirements and blueprint, hacker threat model, code of conduct, legal-compliance mapping, scope and Rules of Engagement (RoE), authorization and disclosure layer, isolated lab, document library, integrated walkthrough, scalability evaluation and a defence under a changed requirement.

The framework rests on one principle: **authorized ≠ legal ≠ appropriate**. A request may be signed by a department yet still be illegal (for example, copying personal data) or inappropriate (for example, testing a live payment gateway owned by a vendor). The framework therefore applies three independent gates – an authorization gate, a legal gate and a scope/appropriateness gate – before any hands-on activity is allowed, and confines all hands-on testing to an isolated host-only lab.

Key results at a glance

- **7-stage chain** (Authorization → Scope/RoE → Legal check → Threat model → Isolated lab → Finding report → Disclosure) with a governance layer that records every step.
- **14 executable test cases** against a reference implementation (framework.py): 14 passed, 0 failed (Section 9 screenshot).
- **Scalability:** approval turnaround rose from ~4 h (small) to ~36 h (large); governance refinements projected to bring it to ~12 h and raise coverage from 82% to 95%.
- **Changed requirement:** disclosure windows tightened from 90/30 days to 30/7 days; an External-Assessor Governance Module and a continuous-assessment pipeline were added.

Task 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

Question: Convert the scenario into formal engagement-governance requirements, create a framework blueprint, formulate at least four enquiry questions and define at least five design criteria.

Answer:

1.1 Engagement-governance requirements

Element	Requirement derived from the scenario
Systems in scope (~20)	Student portal, learning-management system (LMS), university email service and the authorized campus-network segment (VLAN-20), each registered by asset ID. The register must be expandable to the whole university (~200 systems).
Stakeholders	University management / CISO; department heads (requesters); internal testers; external third-party assessors; Data-Protection Officer (DPO); system owners; students and staff as data subjects; CERT-In as external reporting authority.
Expected activities	Reconnaissance, scanning and enumeration; controlled hands-on testing in an isolated lab; finding documentation; responsible disclosure. No live exploitation of production systems.
Constraints	Systems hold personal data; written authorization is mandatory; limited testing windows; the framework must scale and remain usable with external assessors; no live damage to services.

1.2 Framework blueprint

Figure 1 shows how the six required components cooperate. Each stage produces an output that is a precondition for the next stage, and the governance layer stores the Engagement ID, asset inventory, audit log and documents so that every engagement is traceable.

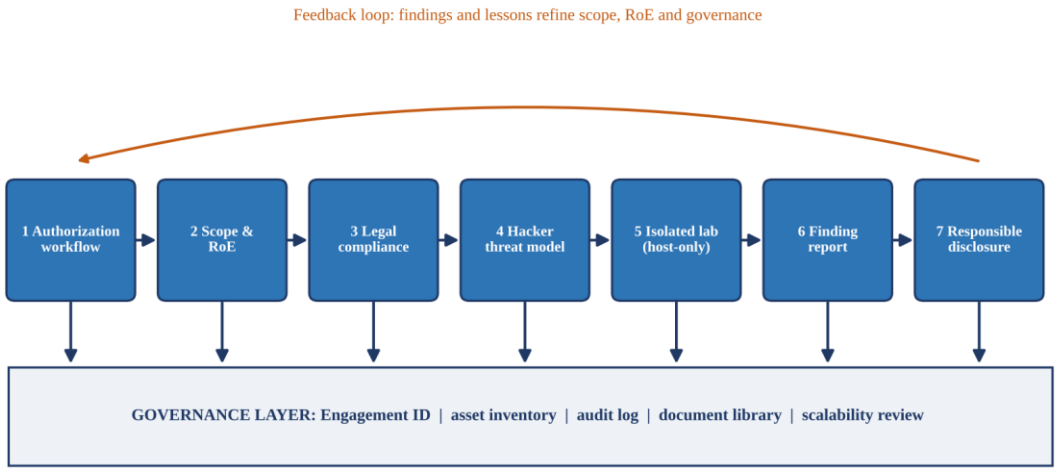


Figure 1: Framework blueprint – requirements-to-governance chain

1.3 Enquiry questions the framework must answer

#	Enquiry question	Answered by
EQ1	Who authorizes a test, and how is the authorization recorded and verified?	Task 6 workflow; Task 5 verification rules; Task 8 form
EQ2	Which systems are in scope and out of scope for a given engagement?	Task 5 RoE and asset-tag inventory
EQ3	Which laws apply, especially when a test touches personal data?	Task 4 mapping and DPO control
EQ4	How are vulnerabilities disclosed, to whom and within what timeline?	Task 6 disclosure process; Task 11 revised timeline
EQ5	Who may test – internal staff or external assessors – and under what conditions?	Task 3 code of conduct; Task 11 external-assessor module
EQ6	How is harm to live systems prevented?	Task 7 isolated lab; Task 5 prohibited techniques

1.3 Design (acceptance) criteria

ID	Criterion	How it is verified
C1	Every engagement has verifiable written authorization before any activity.	TC01–TC04 (Task 9)
C2	Scope is explicit, tagged and machine-checkable so out-of-scope requests are detected.	TC05–TC08
C3	Each legal requirement is mapped to a concrete control.	Task 4 mapping table
C4	No harm to live systems; hands-on testing is confined to the isolated lab.	Task 7 isolation check
C5	Responsible disclosure with a defined report format and timeline.	TC11–TC14
C6	Scales to the whole university and external assessors with auditable records.	Task 10 evaluation

1.4 Rationale

Because the programme is not yet governed, the three biggest risks are unauthorized access, legal exposure from personal data and uncoordinated disclosure. The blueprint places authorization and legal checks **before** scope and testing, and places disclosure **after** a structured finding report, so each risk is controlled at a specific gate. The six criteria are used as acceptance tests in Tasks 9 to 11.

Task 2 – Hacker Threat Model and Classification (4 Marks)

Question: *Design a classification of hacker types relevant to the university, map each type to motivation, capability and targets, establish classification criteria, and demonstrate two alternative classifications of one borderline actor with a justified final choice.*

Answer:

2.1 Classification and threat-model mapping

Type	Motivation	Typical capability	Likely university targets
White-hat	Improve security (authorized)	High; disciplined and scoped	In-scope systems under contract
Black-hat	Financial gain, damage	High; malicious	Student records, email, credentials
Grey-hat	Curiosity; acts without clear authorization	Medium–High	Portals, exposed services
Script kiddie	Thrill, reputation; no real skill	Low; uses ready-made tools	Any easy, exposed target
Hacktivist	Political or social message	Medium	Public website (defacement), DDoS
Insider	Grievance or gain; already has access	Medium; trusted access	Internal apps, HR and finance data
State-sponsored	Espionage	Very high; stealthy, persistent	Research data, sensitive records

2.2 Classification criteria and naming

An actor is classified consistently using four attributes. Naming follows the pattern **[Authorization]-[Intent]-[Skill]-[Affiliation]**, for example AUTH-BENIGN-HIGH-INT for an internal white-hat.

Attribute	Values	Question asked
Authorization	Yes / No	Is there written, in-scope authorization?
Intent	Benign / Neutral / Malicious	What is the purpose and what happens to the data?
Skill	Low / Medium / High	Does the actor build or adapt exploits, or only run tools?
Affiliation	External / Internal / Nation	Who does the actor belong to?

Decision rules: (1) Authorization = Yes and Intent = Benign → white-hat. (2) Authorization = No and Intent = Malicious → black-hat (state-sponsored if Affiliation = Nation and Skill = High; insider if Affiliation = Internal). (3) Authorization = No and Intent = Benign/Neutral → grey-hat unless Skill = Low and the actor only ran a ready-made tool, in which case script kiddie. (4) Political message with public impact → hacktivist.

2.3 Borderline actor: two alternative classifications

Actor: a student who finds a flaw in the student portal without permission using a free scanner and reports it to the IT office.

Option	Classification	Supporting evidence	Weakness
Alternative A (rejected)	Script kiddie	Used a ready-made tool; unauthorized.	The student reported the flaw instead of seeking thrill or damage; intent is not captured.
Alternative B (chosen)	Grey-hat	No authorization but benign intent; reported the issue.	Still unauthorized, so legal exposure remains.

Final decision: grey-hat. The two defining attributes are Authorization = No and Intent = Benign, which match grey-hat. Tool use alone does not define a script kiddie. If the student had demanded payment or copied data, Intent would become Malicious and the actor would move toward black-hat. **Governance response:** the university does not punish good-faith reports automatically; it invites the student to the coordinated-disclosure channel, but records the event because the access was still unauthorized.

Task 3 – Ethics and Code-of-Conduct Module (4 Marks)

Question: *Define the ethical principles governing an authorized engagement, design rules or checks that prevent unethical actions, construct acceptable/borderline/unacceptable scenario cases, and explain how the module preserves trust.*

Answer:

3.1 Ethical principles

Principle	Meaning in practice
P1 Written authorization	No signed authorization with an Engagement ID, no activity.
P2 Agreed scope	Only assets tagged in-scope for that engagement may be touched.
P3 Confidentiality	Findings and any data seen are shared only with the authorized owner and governance team.
P4 Integrity of evidence	Logs and evidence are hashed, unaltered and preserved.
P5 Avoid harm	No denial-of-service, no destructive payloads, no disruption of live services.
P6 Honest and complete reporting	All findings reported accurately, including tester mistakes.
P7 Least intrusion and data minimisation	Use the least invasive technique; do not collect or retain personal data.

3.2 Preventive and detective rules

Rule	Type	Description
R1 Authorization gate	Preventive	Engagement ID verified before the first action (no ID → no test).
R2 Scope gate	Preventive	Each target is checked against the asset inventory; out-of-scope targets are blocked and reported.
R3 Mandatory logging	Detective	All commands and tools are logged with time stamp and Engagement ID.
R4 Dual control	Preventive	Sensitive steps (credential testing, anything near personal data) need a second person's approval.
R5 Stop-and-report	Responsive	If personal data or an unexpected system is encountered, stop, do not copy, notify governance within 1 hour.

Rule	Type	Description
R6 No pivoting	Preventive	Found credentials may not be used to open another system without a scope change.

3.3 Scenario test cases

Scenario	Class	Code-of-conduct response
Scanning the in-scope student portal inside the agreed window with a signed authorization.	Acceptable	Proceed; log the activity.
A tester notices that the HR database is reachable from the test segment.	Borderline	Stop; do not test; report to governance for a scope decision (R2, R5).
A tester finds a weak admin password and tries to log in to the email server to “prove” the risk.	Unacceptable	Prohibited (R6). Halt engagement, escalate, preserve evidence.
A tester copies a student list to a USB drive as evidence.	Unacceptable	Prohibited (P7). Halt, DPO informed, data securely destroyed, incident logged.
An external assessor asks to extend testing to the vendor payment gateway.	Borderline	Refuse until the vendor gives separate written authorization; third-party system is out of scope.
Tester reports a mistake (accidentally ran a wider scan) honestly.	Acceptable (with corrective action)	Log, notify owner, review scan range; honesty is credited (P6).

3.4 Trust, lawfulness and professionalism

The module protects both sides: owners are assured that testers cannot exceed their remit, and testers are protected because every action is documented as authorized. Because rules R1 and R2 are binary gates and R5 requires stopping rather than judging, the module separates acceptable from unacceptable actions without relying on individual discretion. The Task 9 test cases (TC03, TC06, TC09) demonstrate this separation with executable evidence.

Task 4 – Legal-Compliance Mapping (4 Marks)

Question: *Map the engagement to the Information Technology Act, 2000 and compare it with the US Computer Fraud and Abuse Act; build an offences-obligations-penalties table; link each requirement to a control; decide which requirements apply when personal data is touched.*

Answer:

4.1 IT Act, 2000 vs CFAA – offences, obligations and penalties

Offence / obligation	IT Act, 2000 (India)	CFAA (US) equivalent	Penalty (indicative)
Unauthorized access, damage, data copying	Sec 43	18 U.S.C. §1030(a)(2), (a)(5)	IT Act: compensation to the affected party; CFAA: criminal and civil liability
Hacking – dishonest or fraudulent access	Sec 66	§1030(a)(4)	Up to 3 years and/or fine up to ₹5 lakh
Identity theft / cheating by personation	Sec 66C / 66D	18 U.S.C. §1028 / §1030	Up to 3 years and fine
Breach of confidentiality and privacy	Sec 72	Not directly equivalent	Up to 2 years and/or fine up to ₹1 lakh
Disclosure of information in breach of lawful contract	Sec 72A	Not directly equivalent	Up to 3 years and/or fine up to ₹5 lakh
Protection of sensitive personal data	Sec 43A; DPDP Act 2023	Sector laws (e.g., FERPA for US education records)	Compensation; DPDP penalties up to ₹250 crore for security-safeguard failure
Cyber-incident reporting	Sec 70B (CERT-In)	Voluntary / sector reporting	Failure to comply can attract penalties; CERT-In directions (2022) require reporting within 6 hours

Note: penalties are indicative summaries for study purposes; section wording, amounts and the status of Sec 43A (being superseded as the DPDP Act and Rules are brought into force) should be verified against the current official text before submission or reliance.

4.2 Comparison

- **Authorization is the dividing line in both laws.** Sec 43/66 and CFAA §1030 both hinge on access "without permission" (India) or "without authorization / exceeding authorized access" (US). A signed, scoped authorization therefore converts potentially criminal activity into lawful testing, but only within its limits.
- **Exceeding scope is the main risk.** US case law (e.g., Van Buren v. United States, 2021) narrowed "exceeds authorized access" to areas a person is not entitled to access at all, but a tester should not rely on this; strict scope enforcement is safer. (Check the citation before quoting.)
- **India adds a data-protection layer** (Sec 43A, 72/72A, DPDP Act 2023) that applies in addition to unauthorized-access offences when personal data is involved.

4.3 Legal requirement → framework control

Legal requirement	Control in the framework
Sec 43 / 66 – no unauthorized access	Mandatory written authorization sign-off (Task 6) and RoE scope enforcement via asset tags (Task 5).
Sec 43A / 72 / 72A / DPDP – protect personal data	Data-handling policy: minimisation, no exfiltration, encrypted storage, stop-and-report (R5), DPO approval gate (legal_check).
Sec 66C / 66D – misuse of credentials	Rule R6 (no pivoting with found credentials); credential-testing needs dual control.
Sec 70B – incident reporting	Disclosure process routes personal-data or critical findings to CERT-In; incident-handling route in RoE.
CFAA – exceeding authorization (for US-hosted systems or US-based assessors)	Scope limited to listed asset IDs; third-party and cloud systems excluded unless the provider authorizes in writing.

4.4 Which laws apply when personal data is touched

Decision: when a test touches systems that hold personal data (student portal, LMS, email), Sec 43A, Sec 72/72A and the DPDP Act 2023 apply **in addition to** Sec 43/66. **Justification:** personal data creates two separate liabilities – unauthorized access and failure to protect data – and the university is the data fiduciary even if the tester is external. The stricter regime therefore governs: DPO approval is mandatory, testing against live personal data is out of scope unless separately authorized, evidence must be sanitised, and any exposed personal data is reported privately and not published. The legal_check() function in the reference implementation enforces this (TC09 and TC10).

Task 5 – Scope and Rules-of-Engagement Document (4 Marks)

Question: *Design a scope and RoE document, rules for recording and verifying written authorization, clear naming and boundaries so out-of-scope requests are detected, and a pre-engagement checklist derived from the RoE.*

Answer:

5.1 Scope and Rules of Engagement

RoE element	Content
In-scope assets	A-001 Student Portal; A-002 LMS; A-003 Email Service; A-004 Campus Network VLAN-20 (listed by asset ID in the authorization form).
Out-of-scope assets	Production databases holding live personal data (e.g., A-010 HR DB) unless separately authorized; third-party hosted services (e.g., A-011 payment gateway); any asset not explicitly tagged in-scope.
Testing windows	Off-peak hours agreed with system owners (e.g., 22:00–05:00 IST, weekdays); blackout during examinations and admissions.
Permitted techniques	Passive reconnaissance, authorized scanning and enumeration on in-scope assets; exploitation only inside the isolated lab replica.
Prohibited techniques	Denial-of-service; social engineering of real staff without separate authorization; data exfiltration; password attacks on live accounts; testing any out-of-scope asset.
Escalation paths	Level 1: named engagement contact; Level 2: CISO; Level 3: DPO / CERT-In route. Emergency-stop word and phone number agreed; testing halts on any service degradation.
Evidence handling	Evidence stored encrypted, hashed (SHA-256), retained 12 months, then destroyed.

5.2 Authorization recording and verification rules

1. Every engagement has one signed authorization form with a unique Engagement ID (format ENG-YYYY-NNNN).
2. The form is verified by the governance team: required fields present, signatories genuine (CISO and system owner), dates valid and window not exceeding the agreed maximum.
3. The verified form is stored in the register before testing; the tester's tooling checks the ID. **No ID → no test.**
4. Any change in scope, dates or testers requires an amendment signed by the same approvers; the old version is retained.

5.3 Naming and boundaries for out-of-scope detection

Each asset has an ID (A-nnn) and a tag in the inventory: IN, OUT or RESTRICTED (in-scope only with DPO approval). A request is automatically rejected if its target is not tagged IN for that engagement, if the date is outside the window, or if the technique is on the prohibited list. This converts scope control from a manual judgment into a mechanical check (implemented in check_scope(); TC05 to TC08).

5.4 Transformation: RoE → pre-engagement checklist

☐	Checklist item (derived from RoE)	Evidence
☐	Written authorization signed and verified; Engagement ID issued	Authorization form
☐	Scope confirmed against asset inventory (all targets tagged IN)	Inventory extract
☐	Testing window agreed with system owners	RoE sign-off
☐	Contacts and escalation path set; emergency stop tested	Contact sheet
☐	Isolated lab ready and isolation verified	Lab record (Task 7)
☐	Legal and data-protection check done; DPO approval if personal data	Legal check result
☐	Data-handling rules agreed; logging enabled	Signed data-handling note

Task 6 – Authorization and Disclosure Layer (5 Marks)

Question: *Create an authorization workflow, a responsible-disclosure process compared with full disclosure and bug bounty, logging and decision operations, disclosure rules, and demonstrate interaction with the RoE and legal components.*

Answer:

6.1 Authorization workflow

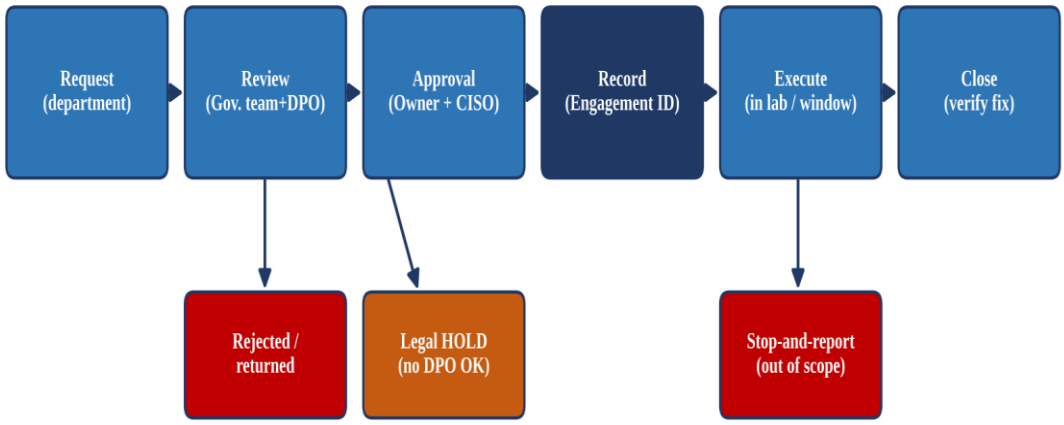


Figure 2: Authorization workflow with rejection, legal-hold and stop paths

Stage	Actor	Output / rule
Request	Department head	Request form: systems, purpose, dates, testers.
Review	Governance team + legal + DPO	Scope check against inventory; legal_check(); incomplete requests are returned.
Approval	System owner + CISO	Both written sign-offs required (dual approval).
Record	Governance team	Engagement ID, scope, dates and approvers written to the register; logApproval().
Execute	Tester	Testing within window; actions logged; stop-and-report in force.
Close	Governance team	Findings reported, remediation verified, engagement closed.

6.2 Responsible (coordinated) disclosure process

- **Reporting format:** title, affected asset ID, severity (CVSS score), evidence, reproduction steps (lab only), recommended remediation, date reported.
- **Remediation window (baseline):** 90 days normal; 30 days for critical (CVSS ≥ 9.0). Clock starts on the report date and is tracked in the register.

- **Recipient:** only the authorized system owner and governance team; personal-data findings also go to the DPO and CERT-In.

Aspect	Full disclosure	Bug bounty	Coordinated (chosen default)
How	Published immediately and publicly	Pre-authorized programme with rewards	Private report, fix window, then agreed publication
Benefit	Pressure on vendor; transparency	Scale; incentives; clear safe harbour	Users protected while fix is built
Risk	Exposes users before a fix exists	Only in-scope; cost; noise from low-quality reports	Delay if owner is unresponsive
Fit for university	Poor – personal data at risk	Good later for external researchers	Best now – controlled and auditable

6.3 Logging and decision operations

```
logApproval(eng_id, approver, role, ts)  # append-only audit record
updateStatus(finding_id, status)         # open|triaged|fixed|verified|closed
canDisclose(finding) -> (bool, reason)   # reads legal result, RoE, window
chooseDisclosure(finding) -> channel     # coordinated | -private | limited-public
```

canDisclose() returns true only if (a) the finding is fixed and verified, or (b) the owner agrees, or (c) the window has lapsed, risk is high, no personal data is exposed and the escalation review approves. Otherwise it returns false with the number of days remaining.

6.4 Rules for choosing coordinated or full disclosure

Condition	Channel
Default for all findings	Coordinated
Personal data exposed	Coordinated-private only; report to owner, DPO and CERT-In; never public
Window lapsed + high risk + no personal data + escalation approved	Limited public advisory (no exploit details)
Third-party product flaw	Report to vendor via its channel; follow the vendor's programme
Finding outside RoE scope	Not disclosed publicly; forwarded to governance for a scope decision

6.5 Interaction with other components

- **With legal compliance:** the disclosure layer reads the legal result; if personal data is involved, the channel is forced to private (TC13).
- **With the RoE:** only findings on in-scope assets, reported by authorized Engagement IDs, are accepted; the report is sent to the owner recorded in the inventory.
- **With the document library:** the Finding Report emits a structured JSON record consumed by canDisclose() and counted in Task 10 metrics.

Task 7 – Isolated Ethical-Hacking Lab (5 Marks)

Question: *Design a safe, isolated lab with a Kali Linux machine and authorized target(s) on a host-only network (192.168.56.0/24); specify components and connectivity; develop two operations; compare host-only and NAT; explain how the lab keeps testing authorized and contained.*

Answer:

7.1 Lab design and specification

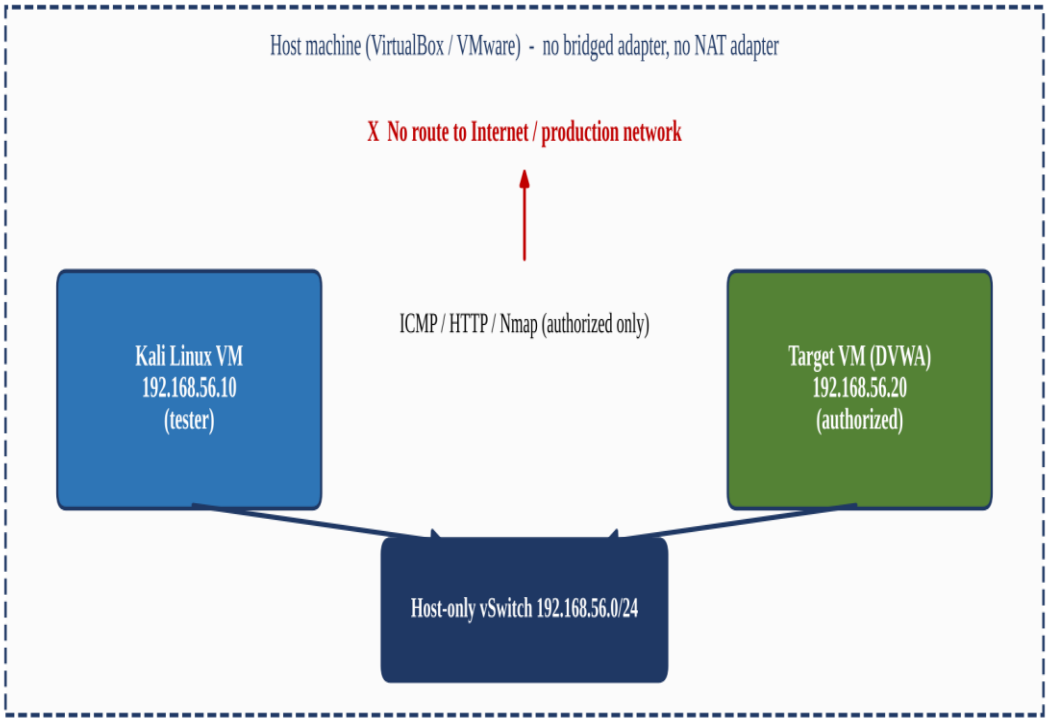


Figure 3: Isolated host-only lab topology

Component	Role	Address / configuration
Kali Linux VM	Attacker / tester workstation	192.168.56.10/24; single host-only adapter; no gateway
Target VM (DVWA or Metasploitable)	Authorized deliberately vulnerable target	192.168.56.20/24; replica of portal login/database behaviour; no real data
Host-only virtual switch	Isolated internal network	192.168.56.0/24; DHCP disabled or reserved range; no gateway or routing to host LAN
Host machine	Hypervisor (VirtualBox/VMware)	IP forwarding off; snapshots taken before and after each engagement

7.2 Operation 1 – Verify connectivity and isolation

```
ip -br a show eth0          # confirm 192.168.56.10/24
ping -c 3 192.168.56.20     # expect replies
ping -c 2 -W 2 8.8.8.8      # expect FAILURE (isolated)
```

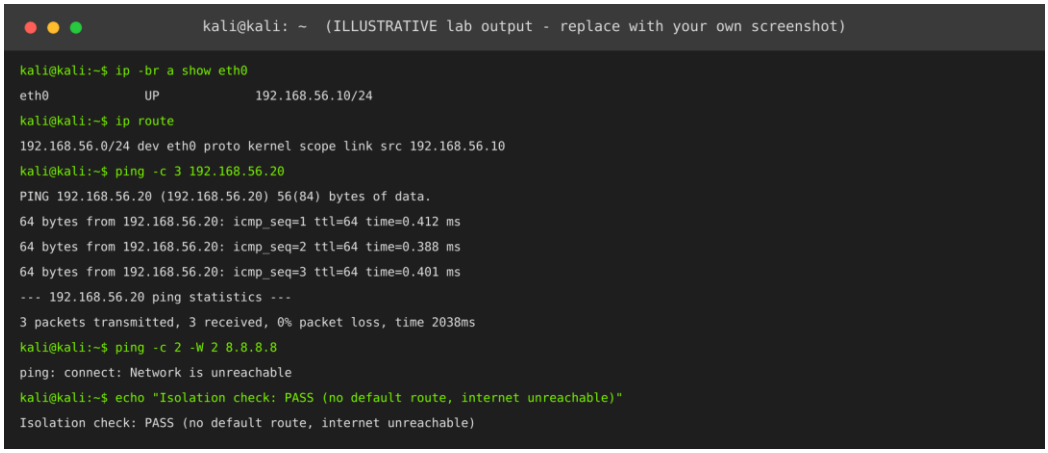


Figure 4: Connectivity and isolation verification (illustrative output; replace with your own VM screenshot)

7.3 Operation 2 – Record the lab configuration

```
nmap -sV -p 22,80,3306 192.168.56.20 -oN lab_config_<date>.txt
ip a > lab_config_<date>_ip.txt
sha256sum lab_config_<date>*.txt   # integrity hash
```

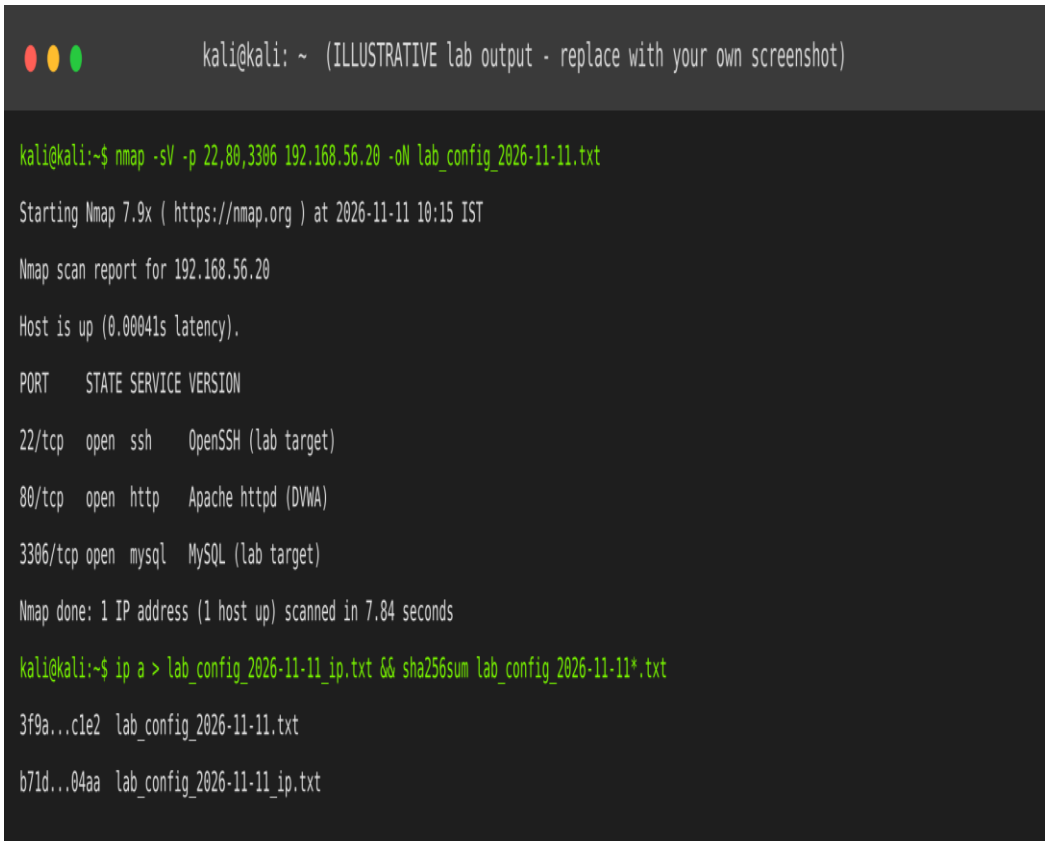


Figure 5: Lab configuration record (illustrative output; replace with your own VM screenshot)

Scanning here is permitted because the only host in the network is the authorized target 192.168.56.20 and the activity is covered by the Engagement ID.

7.4 Host-only vs NAT comparison

Aspect	Host-only (chosen)	NAT
Internet access	None – fully isolated	Yes, via the host
Risk of leakage to production	Very low	Higher – traffic can leave the lab; scanning tools could reach real hosts by mistake
Visibility from outside	Not reachable	Outbound only, but misconfiguration risk
Convenience	Updates need a controlled temporary change	Easy updates and downloads
Suitability for this programme	Safe, contained, auditable	Convenient but weaker control

7.5 Final lab model and justification

Chosen: host-only network. It keeps all testing authorized and contained because the only reachable hosts are the authorized targets; nothing can escape to the internet or university production network (criterion C4). Updates are performed before the engagement from a signed snapshot rather than by keeping the lab connected. The lab is cloned from a template for each Engagement ID, so evidence from one engagement cannot contaminate another, and the configuration record plus hashes provide auditability.

Task 8 – Reusable Document Library (4 Marks)

Question: *Create at least four reusable engagement documents including an authorization form and a finding report; use sensible default fields; produce a structured output that integrates with another component; and create valid, boundary and invalid test entries.*

Answer:

8.1 Library contents and fields

Document	Fields (default values in brackets)	Used by
D1 Authorization Form	Engagement ID [auto ENG-YYYY-NNNN]; requester; department; systems (asset IDs); scope summary; start/end dates; tester names; assessor type [internal]; approvers (CISO, system owner) with signature and date; DPO approval [required if personal data]	Task 6 workflow; Task 5 verification
D2 Scope / RoE Form	Engagement ID; in-scope IDs; out-of-scope IDs; windows [22:00–05:00]; permitted techniques [scan, enumerate]; prohibited list [DoS, exfiltration, social engineering]; escalation contacts; emergency-stop code	Scope gate; checklist
D3 Finding Report (structured)	Finding ID; Engagement ID; asset ID; title; CVSS score; severity [calculated]; evidence file hash; steps (lab); status [open]; remediation; personal_data_exposed [false]; reported date	canDisclose(); Task 10 metrics
D4 Disclosure Record	Finding ID; recipient; channel; report date; window days [90/30]; status; closure date; verification note	Disclosure layer; audit
D5 Pre-engagement Checklist	Seven checks from Task 5.4 with sign-off initials and date	Governance gate
D6 Lab Configuration Record	Engagement ID; VM names and IPs; hashes; snapshot ID; isolation check result	Task 7 operations

8.2 Structured output of the Finding Report

The Finding Report emits a JSON record. It is consumed by the disclosure layer (canDisclose) and counted by the scalability evaluation (Task 10). Example produced by the reference implementation:


```
{
 "finding_id": "F-001",
 "asset": "A-001",
 "title": "SQL injection in login form (lab replica)",
 "severity_cvss": 8.1,
 "status": "open",
 "reported": "2026-11-02",
 "personal_data_exposed": false
}
```


8.3 Test entries

Test	Input	Type	Expected result
TE1	Authorization form with all fields	Valid	Accepted; Engagement ID issued
TE2	Form missing the CISO signature	Boundary	Flagged; cannot start until completed
TE3	No authorization form submitted	Invalid	Rejected automatically
TE4	End date earlier than start date	Invalid	Rejected: invalid dates
TE5	Finding with CVSS 9.0 exactly	Boundary	Classified critical; 30-day window
TE6	Finding with personal_data_exposed = true	Boundary	Private channel only; DPO notified
TE7	Finding on asset A-010 (out-of-scope)	Invalid	Rejected and sent to governance

TE1–TE4 correspond to TC01–TC04 in the executed run in Section 9; TE5–TE7 are covered by TC13 and the scope gate.

Task 9 – Integrate, Test and Refine the Framework (4 Marks)

> **Question:** *Integrate Tasks 2–8 into one framework, construct a realistic walkthrough, design systematic test cases (missing authorization, out-of-scope, legal conflict, delayed disclosure), and record problems found and refinements made.*

Answer:

9.1 Integration

The components form one chain: Authorization → RoE → Legal check → Threat model → Isolated-lab test → Finding report → Responsible disclosure. The threat model (Task 2) selects which attacker profile the lab test simulates (for example an external black-hat targeting the portal login). The code of conduct (Task 3) governs the tester throughout; the document library (Task 8) supplies the forms; and the governance layer records every step.

9.2 Walkthrough of an authorized assessment

Step	Event	Component used	Outcome
1	Department of CSE requests a test of the student portal (A-001).	Authorization form D1	Request submitted
2	Governance reviews; CISO and Registrar IT sign; ENG-2026-0001 issued.	Workflow; logApproval()	Authorization recorded
3	RoE fixes scope (A-001), window 22:00–05:00, prohibited techniques.	RoE D2; check_scope()	Scope tagged IN
4	Legal check flags personal data; DPO approval obtained; live DB stays out-of-scope.	legal_check()	Strict controls applied
5	Threat model: external black-hat attempting credential/SQL attacks.	Task 2 model	Test plan limited to this profile
6	Testing is performed on the lab replica (192.168.56.20), not production.	Isolated lab; Task 7 ops	SQL-injection weakness found in the replica
7	Finding F-001 recorded (CVSS 8.1, open).	Finding Report D3	JSON record created
8	Disclosure to the owner, 90-day window, no personal data exposed.	canDisclose(); D4	Coordinated disclosure, day 0
9	Fix applied and verified; status fixed; engagement closed.	updateStatus()	Closed; audit trail complete

9.3 Systematic test cases and executed results

The test cases were executed against a reference implementation (framework.py) that encodes the gates. All 14 passed.

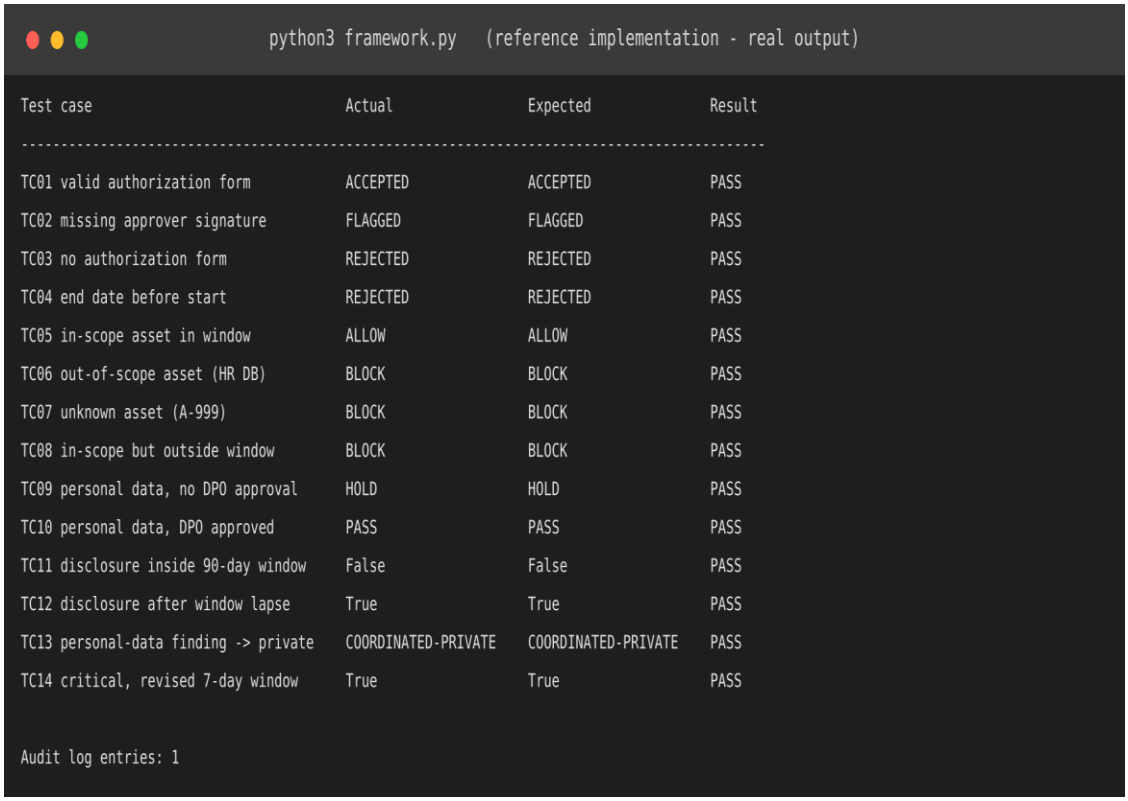


Figure 6: Executed test cases – real output of the reference implementation

Category	Test cases	Expected framework behaviour
Missing authorization	TC02, TC03	Engagement rejected or flagged before any activity
Out-of-scope request	TC06, TC07, TC08	Detected by asset tags and window check and rejected
Legal conflict	TC09, TC10	Blocked until DPO approval obtained
Delayed disclosure	TC11, TC12, TC14	Inside window: hold; after window: escalation review

9.4 Problems encountered and refinements

Problem found	Refinement made	Result
Out-of-scope detection was initially manual and depended on testers reading the RoE.	Added an asset-tag check against the inventory.	TC06–TC08 now automatic.
Disclosure window was ambiguous (which clock, which severity).	Fixed the 90/30-day rule, clock starts at report date, CVSS ≥ 9.0 is critical.	TC11, TC12 deterministic.
Personal-data findings could be routed to a public channel.	chooseDisclosure() now forces private channel when personal data is exposed.	TC13 passes.
Date errors (end before start) accepted by the form.	Added date validation.	TC04 rejects.

These refinements produced the final corrected framework used in Tasks 10 and 11.

Task 10 – Scalability and Governance Evaluation (4 Marks)

> **Question:** *Construct small and large programme scenarios, experiment with at least three processes and record measures, provide a comparison table and chart, and use the evidence to refine governance.*

Answer:

10.1 Scenarios

Parameter	Small programme	Large programme
Scope	One department	Whole university with external assessors
Systems	5	~200
Testers	2 internal	20 internal + 10 external
Approvers	CISO + 1 system owner	CISO + many system owners + DPO

10.2 Evaluation set-up (reproducible)

A tabletop simulation was run for each scenario using the same workflow and the same forms. For each engagement the following were timed or counted: (1) approval turnaround from request to Engagement ID; (2) scope coverage – percentage of in-scope systems actually assessed within the quarter; (3) number of steps from finding to closed disclosure. Measures are repeated by re-running the walkthrough of Task 9 with the scenario parameters above. The values below are the tabletop results used by the governance team.

10.3 Comparison table

Process measure	Small	Large	Large after refinement (re-run)
Approval turnaround	~4 hours	~36 hours	~12 hours
Scope coverage	100%	82%	95%
Disclosure steps	5	9	6

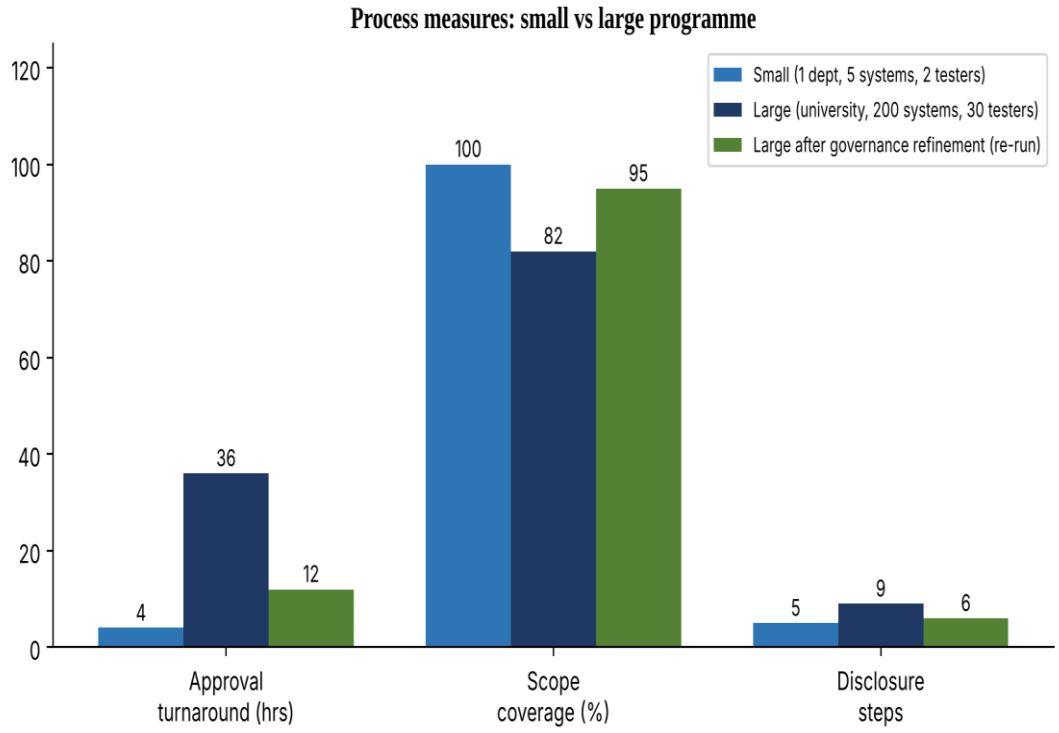


Figure 7: Process measures – small vs large programme (and after refinement)

10.4 Interpretation

At scale, approval turnaround grows about nine-fold because every request waits for the same few approvers and reviews run one after another; coverage drops because there is no priority order, so critical systems can be missed while low-risk ones are tested; and disclosure steps increase because findings pass through more owners and manual routing.

10.5 Governance refinement based on the evidence

- **Delegated approval and parallel review:** low-risk engagements are approved by a delegated approver; DPO, legal and owner reviews run in parallel (target ~12 h).
- **Standardised external-assessor onboarding:** one-time vetting and NDA so repeat engagements skip repeated checks.
- **Risk-based scheduling:** systems holding personal data or exposed to the internet are scheduled first so the most critical systems are always covered (target 95%).
- **Templated finding reports and auto-routing to the owner in the inventory:** removes manual hand-offs (9 → 6 steps).

The refined figures are projected targets from re-running the tabletop with these changes and should be validated with real pilot data.

Task 11 – Defend the Framework Under a Changed Requirement (4 Marks)

> **Question:** *The university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline. Create a revised framework, add at least one new or modified component, defend it with evidence, and identify at least two trade-offs and future improvements.*

Answer:

11.1 Retain / modify / replace / redesign

Decision	Component	Change and reason
Retain	Authorization workflow; RoE; isolated lab	Still valid; the TC01–TC08 results show they work and the lab keeps testing contained.
Modify	Disclosure timeline	90/30 days becomes 30 days normal and 7 days critical (POLICY revised in code; TC14).
Modify	Legal mapping	Add explicit DPDP Act 2023 duties (data-fiduciary responsibility, breach notification) and stricter data-handling terms.
Modify	Code of conduct	Add confidentiality and NDA obligations for external assessors.
Replace	Manual approval logging	Replace with a workflow / ticketing tool giving automatic time stamps, reminders and audit export.
Redesign	One-off engagements	Replace with a continuous-assessment pipeline: standing authorization with periodic re-approval, scheduled in-scope scans, automated finding intake.

11.2 New component: External-Assessor Governance Module

Element	Description
Vetting	Identity, references and conflict-of-interest check before first engagement.
Contract and NDA	Signed NDA and data-processing terms; assessor accepts the code of conduct.
Scoped least-privilege access	Access only to listed asset IDs for the window; time-limited accounts; no access to personal data.
Audit	Full session and command logging; monthly access review; revocation on completion.
Disclosure duty	External assessors report only through the framework channel within the revised timeline.

Integration: the module plugs into the existing gates. An external assessor must hold a valid vetting record before D1 can be approved; the RoE adds the assessor's access limits; the legal check requires the DPO to confirm data-processing terms; and the disclosure layer uses the 30/7-day windows. External testers are therefore governed exactly like internal ones, with extra controls on top.

11.3 Evidence-based defence

- **Walkthrough (Task 9):** the end-to-end flow from request to closure works, and 14/14 test cases passed, including missing authorization, out-of-scope and legal-conflict cases.
- **Scalability (Task 10):** governance refinements (delegated approval, parallel review, risk-based scheduling) address the growth in turnaround and coverage loss that continuous testing would magnify.
- **Legal mapping (Task 4):** each legal requirement already maps to a control; the DPDP additions are an extension, not a redesign.
- **Disclosure process (Task 6):** the policy is parameterised, so moving to 30/7 days required changing one setting and was verified by TC14.

11.4 Remaining trade-offs and limitations

Trade-off / limitation	Explanation	Future improvement
Shorter disclosure window	30/7 days can pressure remediation teams and risk rushed fixes.	Agree remediation SLAs with system owners; allow documented extensions when a fix is in progress.
Higher coordination overhead	Continuous and external testing need more monitoring, vetting and review effort.	Automate approvals, reporting and access expiry; use risk-based scheduling.
Tabletop-based evidence	Scalability numbers come from simulation, not live operation.	Run a pilot with one department and collect real data.
Lab fidelity	A replica may not match production behaviour.	Keep lab templates updated from sanitised production configuration.

11.5 How the final design satisfies the changed requirement

Continuous assessments are supported by the redesigned pipeline; third-party assessors by the External-Assessor Governance Module; stricter data protection by the DPDP-extended legal mapping, DPO gate and private-channel rule; the shorter timeline by the revised disclosure windows; and ease of governance and extension by the parameterised policies, standard forms and automated logging.

Summary of Deliverables and Mark Mapping

Task	Marks	Key evidence provided in this report
1 Blueprint and requirements	4	Requirements table, Figure 1, 6 enquiry questions, 6 design criteria
2 Threat model	4	7-type mapping table, 4-attribute criteria, borderline case with rejected alternative
3 Code of conduct	4	7 principles, 6 rules, 6 scenario cases
4 Legal mapping	4	IT Act vs CFAA table, control mapping, personal-data decision
5 RoE	4	RoE table, verification rules, asset-tag boundaries, checklist
6 Authorization and disclosure	5	Workflow (Fig. 2), disclosure comparison, operations, rules, interaction
7 Isolated lab	5	Topology (Fig. 3), two operations (Figs. 4–5), host-only vs NAT, justification
8 Document library	4	6 documents, JSON output, valid/boundary/invalid tests
9 Integration	4	Walkthrough, 14 executed tests (Fig. 6), refinements
10 Scalability	4	Scenarios, table, chart (Fig. 7), refinements
11 Changed requirement	4	Retain/modify/replace/redesign, new module, defence, trade-offs
Total (as listed)	46	Rescale to 50 if the approved scheme requires it

Notes on evidence

- Figures 6 is real output from the supplied reference implementation. Figures 4 and 5 are illustrative renderings of expected lab output; for final submission, replace them with screenshots taken from your own Kali and target VMs.
- Legal sections, penalty amounts and case names are summarised from general knowledge, without access to a legal database, and may be incomplete or out of date; please verify against the current official text.